

МИНИСТЕРСТВО НАУКИ И ВЫСШЕГО ОБРАЗОВАНИЯ РОССИЙСКОЙ ФЕДЕРАЦИИ
ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ УНИВЕРСИТЕТ ИТМО»

Факультет безопасности информационных технологий

Дисциплина:

“Программно-аппаратные средства защиты информации”

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №1

Механизмы защиты Unix систем

Выполнили:

Гачко Григорий Дмитриевич, студент группы N3345

Подпись: _____

Жук Анастасия Валерьевна, студентка группы N3348

Подпись: _____

Проверил:

Чешев Никита Игоревич

(подпись)

Санкт-Петербург
2025г.

СОДЕРЖАНИЕ

ВВЕДЕНИЕ.....	3
СОКРАЩЕНИЯ.....	4
ХОД РАБОТЫ.....	5
Определение дистрибутива.....	5
Ответы на вопросы.....	6
Требования к защите. Нормативные документы.....	15
Настройка Unix системы.....	31
Настройки безопасности.....	32
Настройка авторизации в операционных системах Linux.....	32
Ограничение механизмов получения привилегий.....	33
Настройка прав доступа к объектам файловой системы.....	35
Настройка механизмов защиты ядра Linux.....	45
ВЫВОД.....	47
СПИСОК ИСПОЛЬЗУЕМЫХ ИСТОЧНИКОВ.....	48

ВВЕДЕНИЕ

Цель работы: ознакомление с базовыми модулями защиты Unix систем.

Для достижения поставленной цели необходимо решить следующие задачи:

- Предопределить дистрибутив.
- Определить, в какой системе расположен защищаемый эндпоинт.
- Предопределить требования к защите с помощью нормативной базы.
- Выполнить настройку Unix системы в соответствии с требованиями регуляторов.

СОКРАЩЕНИЯ

ИСУ – информационная система университета;

ГИС – государственная информационная система;

ИСПДн – информационная система персональных данных;

ВМ – виртуальная машина;

ПО – программное обеспечение;

ОС – операционная система;

ГОСТ – государственный стандарт;

ФСТЭК – федеральная служба по техническому и экспортному контролю;

ЗИ – защита информации;

НСД – несанкционированный доступ;

ИС – информационная система;

ФЗ – федеральный закон;

УЗ – учетная запись.

ХОД РАБОТЫ

Определение дистрибутива

Наши порядковые номера в группах ИСУ - 10 и 7, а значит доступные нам варианты лабораторной работы вычисляется следующим образом:

$$10 \% 25 = 10 \text{ и } 7 \% 25 = 7.$$

У нас на выбор два варианта: 7 (Qubes OS и ГИС (Федеральный)) и 10 (Parrot Security OS и ГИС (Федеральный) + ИСПДн).

Дистрибутив, с которым мы будем работать, - Parrot OS, а защищаемый эндпоинт расположен в ГИС (Федеральный) - государственной информационной системе и ИСПДн – информационной системе персональных данных.

Ответы на вопросы

Ответы на поставленные вопросы можно найти в ГОСТ Р 56938-2016 «Защита информации. Защита информации при использовании технологий виртуализации».

1. Какие угрозы безопасности появляются, когда мы используем виртуальные машины (ВМ) вместо физических серверов?

Ответ: использование технологий виртуализации создает предпосылки для появления угроз безопасности, не характерных для информационных систем, построенных без использования технологий виртуализации.

1. Угрозы атаки на активное и/или пассивное виртуальное и/или физическое сетевое оборудование из физической и/или виртуальной сети.
2. Угрозы атаки на виртуальные каналы передачи.
3. Угрозы атаки на гипервизор из виртуальной машины и/или физической сети.
4. Угрозы атаки на защищаемые виртуальные устройства из виртуальной и/или физической сети.
5. Угрозы атаки на защищаемые виртуальные машины из виртуальной и/или физической сети.
6. Угрозы атаки на защищаемые виртуальные машины из виртуальной и/или физической сети.
7. Угрозы атаки на систему хранения данных из виртуальной и/или физической сети.
8. Угрозы выхода процесса за пределы виртуальной машины.
9. Угрозы несанкционированного доступа к данным за пределами зарезервированного адресного пространства, в том числе выделенного под виртуальное аппаратное обеспечение.

10. Угрозы нарушения изоляции пользовательских данных внутри виртуальной машины.
11. Угрозы нарушения процедуры аутентификации субъектов виртуального информационного взаимодействия.
12. Угрозы перехвата управления гипервизором.
13. Угрозы перехвата управления средой виртуализации.
14. Угрозы неконтролируемого роста числа виртуальных машин.
15. Угрозы неконтролируемого роста числа зарезервированных вычислительных ресурсов.
16. Угрозы нарушения технологии обработки информации путем несанкционированного внесения изменений в образы виртуальных машин.
17. Угрозы несанкционированного доступа к хранимой в виртуальном пространстве защищаемой информации.
18. Угрозы ошибок обновления гипервизора.

2. *Как правильно настроить и управлять виртуальной инфраструктурой, чтобы она была защищена?*

Ответ: мерами защиты средств создания и управления виртуальной инфраструктурой являются:

- автоматическое изменение маршрутов передачи сетевых пакетов между компонентами виртуальной инфраструктуры внутри гипервизора;
- блокировка доступа к объектам виртуальной инфраструктуры для субъектов доступа, не прошедших процедуру аутентификации;
- выявление, анализ и блокирование внутри виртуальной инфраструктуры скрытых каналов передачи информации в обход реализованных мерЗИ или внутри разрешенных сетевых протоколов;

- защита от НСД к вводимой субъектами доступа, входящими в состав виртуальной инфраструктуры, аутентификационной информации;
- защита от НСД к хранящейся в компонентах виртуальной инфраструктуры аутентификационной информации о субъектах доступа;
- идентификация и аутентификация субъектов доступа при их локальном или удаленном обращении к объектам виртуальной инфраструктуры;
- идентификация и аутентификация субъектов доступа при осуществлении ими попыток доступа к консолям управления параметрами аппаратного обеспечения;
- контроль ввода (вывода) информации в/из виртуальную(ой) инфраструктуру(ы);
- контроль ввода (вывода) информации в/из ИС;
- контроль доступа субъектов доступа к изолированному адресному пространству в памяти гипервизора;
- контроль доступа субъектов доступа к изолированному адресному пространству в памяти хостовой операционной системы;
- контроль доступа субъектов доступа к средствам конфигурирования виртуального аппаратного обеспечения;
- контроль доступа субъектов доступа к средствам конфигурирования гипервизора и ВМ;
- контроль доступа субъектов доступа к средствам конфигурирования хостовой и/или гостевых операционных систем;
- контроль запуска гипервизора и ВМ на основе заданных критериев обеспечения безопасности объектов защиты (режим запуска, тип используемого носителя и т. д.);
- контроль запуска хостовой и/или гостевых операционных систем на основе заданных критериев обеспечения безопасности объектов защиты (режим запуска, тип используемого носителя и т. д.);

- контроль передачи служебных информационных сообщений, передаваемых в виртуальных сетях хостовой операционной системы, по следующим характеристикам: составу, объему и др.;
- контроль работоспособности дублирующих ключевых компонентов аппаратного обеспечения ИС;
- контроль работоспособности дублирующих ключевых компонентов виртуальной инфраструктуры;
- контроль целостности компонентов, критически важных для функционирования гипервизора и ВМ;
- контроль целостности компонентов, критически важных для функционирования хостовой и гостевых операционных систем;
- контроль целостности микропрограммного обеспечения аппаратной части ИС;
- мониторинг загрузки мощностей физического и виртуального аппаратного обеспечения;
- обеспечение возможности наследования установленных на уровне управления прав доступа субъектов доступа к объектам доступа на уровне виртуализации и оборудования;
- обеспечение изоляции различных потоков данных, передаваемых и обрабатываемых компонентами виртуальной инфраструктуры хостовой операционной системы;
- обеспечение подлинности сетевых соединений (сеансов взаимодействия) внутри виртуальной инфраструктуры, в том числе для защиты от подмены сетевых устройств и сервисов;
- отключение неиспользуемых сетевых протоколов компонентами виртуальной инфраструктуры хостовой операционной системы;

- предотвращение задержки или прерывания выполнения в виртуальной инфраструктуре процессов с высоким приоритетом со стороны процессов с низким приоритетом;
- предотвращение задержки или прерывания выполнения процессов ВМ с высоким приоритетом со стороны процессов ВМ с низким приоритетом;
- применение индивидуальных прав доступа к объектам доступа субъектов доступа для одного или совокупности компонентов виртуальной инфраструктуры;
- проверка наличия вредоносных программ в загрузочных областях машинных носителей информации, подключенных к ИС;
- проверка наличия вредоносных программ в микропрограммном обеспечении физического и виртуального аппаратного обеспечения;
- проверка наличия вредоносных программ в файлах конфигурации гипервизора и/или ВМ;
- проверка наличия вредоносных программ в файлах конфигурации хостовой и гостевых операционных систем;
- проверка наличия вредоносных программ в файлах-образах виртуализованного ПО и ВМ, а также файлах-образах, используемых для обеспечения работы виртуальных файловых систем;
- проверка оперативной памяти и файловой системы гипервизора и/или ВМ на наличие вредоносных программ;
- проверка оперативной памяти и файловой системы хостовой и/или гостевых операционных систем на наличие вредоносных программ;
- размещение сенсоров и/или датчиков систем обнаружения (предотвращения) вторжений в виртуальном аппаратном обеспечении;
- размещение сенсоров и/или датчиков систем обнаружения (предотвращения) вторжений в гипервизоре и/или ВМ;

- размещение сенсоров и/или датчиков систем обнаружения (предотвращения) вторжений в хостовой и/или гостевых операционных системах;
- регистрация и учет запуска (завершения) работы компонентов виртуальной инфраструктуры;
- регистрация входа (выхода) субъектов доступа в/из гипервизор(а) и/или ВМ;
- регистрация входа (выхода) субъектов доступа в/из хостовую(ой) и/или гостевые(х) операционные(х) системы (систем);
- регистрация запуска (завершения работы) гипервизора и/или ВМ, программ и процессов в гипервизоре и/или ВМ;
- регистрация запуска (завершения работы) хостовой и/или гостевых операционных систем, программ и процессов в хостовой и/или гостевых операционных системах;
- регистрация и учет изменений в составе программной и аппаратной части ИС во время ее функционирования и/или в период ее аппаратного отключения;
- регистрация изменений правил доступа к виртуальному аппаратному обеспечению;
- регистрация изменений состава и конфигурации виртуального аппаратного обеспечения;
- регистрация изменений состава и конфигурации ВМ;
- регистрация изменений состава ПО и виртуального аппаратного обеспечения в гипервизоре и/или ВМ;
- регистрация изменений состава ПО и виртуального аппаратного обеспечения в хостовой и/или гостевых операционных системах;

- регистрация изменения правил доступа к информации ограниченного доступа, хранимой и обрабатываемой в гипервизоре и/или ВМ;
- регистрация изменения правил доступа к информации ограниченного доступа, хранимой и обрабатываемой в хостовой и/или гостевых операционных системах;
- резервирование пропускной способности канала связи для обеспечения стабильного взаимодействия между компонентами виртуальной инфраструктуры внутри гипервизора;
- резервное копирование защищаемой информации в гипервизоре и/или ВМ, хранимой на физических и/или виртуальных носителях информации;
- резервное копирование защищаемой информации в хостовой и/или гостевых операционных системах, хранимой на физических и/или виртуальных носителях информации;
- резервное копирование физического и/или виртуального дискового пространства, используемого для хранения журналов событий гипервизора и/или ВМ;
- своевременное обнаружение отказов компонентов виртуальной инфраструктуры;
- создание (имитация) ложных компонентов виртуальной инфраструктуры, предназначенных для обнаружения, регистрации и анализа действий нарушителей в процессе реализации угроз безопасности;
- стирание остаточной информации, образующейся после удаления данных, обрабатываемых в виртуальной инфраструктуре, содержащих информацию ограниченного доступа;
- стирание остаточной информации, образующейся после удаления данных, содержащих информацию ограниченного доступа, в гипервизоре и/или ВМ;

- стирание остаточной информации, образующейся после удаления данных, содержащих информацию ограниченного доступа, в хостовой и/или гостевых операционных системах;
- стирание остаточной информации, образующейся после удаления файлов, содержащих настройки виртуализованного ПО и виртуального аппаратного обеспечения;
- управление доступом к аппаратному обеспечению ИС, контроль подключения (отключения) машинных носителей информации;
- управление запуском (обращениями) компонентов ПО, в том числе определение запускаемых компонентов, настройка параметров запуска компонентов, контроль за запуском компонентов ПО;
- управление установкой (инсталляцией) компонентов ПО, входящего в состав виртуальной инфраструктуры, в том числе определение компонентов, подлежащих установке, настройка параметров установки компонентов, контроль за установкой компонентов ПО;
- установка (инсталляция) только разрешенного к использованию в виртуальной инфраструктуре ПО и/или его компонентов;
- фильтрация сетевого трафика между компонентами виртуальной инфраструктуры и внешними сетями хостовой операционной системы, в том числе сетями общего пользования;
- фильтрация сетевого трафика от/к каждой гостевой операционной системы(е).

3. Какие требования предъявляются к средствам защиты информации (СЗИ) в такой среде?

Ответ: мерами защиты виртуальных средств защиты информации и средств защиты информации, предназначенных для использования в среде виртуализации, являются:

- автоматическое восстановление всех функций средств ЗИ, входящих в состав ИС;

- защита от НСД к вводимой субъектами доступа, входящими в состав виртуальной инфраструктуры, аутентификационной информации;
- защита от НСД к хранящейся в компонентах виртуальной инфраструктуры аутентификационной информации о субъектах доступа;
- идентификация и аутентификация субъектов доступа при их локальном или удаленном обращении к объектам виртуальной инфраструктуры;
- обеспечение возможности наследования установленных на уровне управления прав доступа субъектов доступа к объектам доступа на уровне виртуализации и оборудования;
- обеспечение доверенных канала, маршрута внутри виртуальной инфраструктуры между администратором, пользователем и средствами ЗИ (функциями безопасности средств ЗИ).

Требования к защите. Нормативные документы

Работать мы будем с ГИС (Федеральный), то есть с *государственной информационной системой федерального масштаба*. Основными документами, описывающими требования к защите ГИС являются **Федеральный закон** от 27.07.2006 № 149-ФЗ «Об информации, информационных технологиях и о защите информации» и **приказ ФСТЭК России** от 11.02.2013 № 17 (ред. от 28.08.2024) «Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах», а также стоит обратить внимание на **Федеральный закон** от 26.07.2017 № 187-ФЗ «О безопасности критической информационной инфраструктуры Российской Федерации» и **приказ ФСТЭК России** от 25.12.2017 № 239 (ред. от 28.08.2024) «Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации». Федеральные законы дают определения, устанавливают общие требования и принципы, назначают ответственных, устанавливают ответственность, то есть создают правовое поле. В свою очередь приказы ФСТЭК устанавливают классификации, определяют конкретные меры защиты, детализируют технические требования, описывают организационные меры, то есть являются детальными, техническими инструкциями. Но без ФЗ сложно понять приказы, поэтому нужно смотреть и то, и другое.

Итак, теперь концентрируем наше внимание именно на типе ИС, который нам достался. Согласно Федеральному закону № 187-ФЗ, все государственные информационные системы федерального масштаба являются значимыми объектами КИИ. А для КИИ есть свои, обязательные к исполнению приказы ФСТЭК. Поэтому важно учесть приказы № 17 и № 239. Для определения состава мер защиты информации и их базовых

наборов необходимо определить класс защищенности ИС. *Класс защищенности информационной системы* (первый класс (К1), второй класс (К2), третий класс (К3)) определяется в зависимости от уровня значимости информации (УЗ), обрабатываемой в этой информационной системе, и масштаба информационной системы (федеральный, региональный, объектовый). Существует таблица для определения класса:

Таблица 1 - Классы защищенности ИС

Уровень значимости информации	Масштаб информационной системы		
	Федеральный	Региональный	Объектовый
УЗ 1	К1	К1	К1
УЗ 2	К1	К2	К2
УЗ 3	К2	К3	К3

Уровень значимости информации определяется степенью возможного ущерба для обладателя информации (заказчика) и/или оператора от нарушения конфиденциальности (неправомерный доступ, копирование, предоставление или распространение), целостности (неправомерные уничтожение или модифицирование) или доступности (неправомерное блокирование) информации.

Масштаб рассматриваемой нами информационной системы - федеральный, а уровень значимости - УЗ 1, так как нарушение конфиденциальности, целостности или доступности информации может повлечь за собой существенный ущерб для государства на федеральном уровне. Поэтому класс защищенности ГИС (Федеральный) - К1. А это значит, что исходя из приложений к Требованиям из приказов ФСТЭК, мы должны обеспечивать следующие меры защиты информации:

1. Идентификация и аутентификация:

- 1.1. Регламентация правил и процедур идентификации и аутентификации;
- 1.2. Идентификация и аутентификация пользователей и инициируемых ими процессов;
- 1.3. Идентификация и аутентификация устройств;
- 1.4. Управление идентификаторами;
- 1.5. Управление средствами аутентификации;
- 1.6. Идентификация и аутентификация внешних пользователей;
- 1.7. Защита аутентификационной информации при передаче.
2. Управление доступом:
 - 2.1. Регламентация правил и процедур управления доступом;
 - 2.2. Управление учетными записями пользователей;
 - 2.3. Реализация модели управления доступом;
 - 2.4. Доверенная загрузка;
 - 2.5. Разделение полномочий (ролей) пользователей;
 - 2.6. Назначение минимально необходимых прав и привилегий;
 - 2.7. Ограничение неуспешных попыток доступа в информационную (автоматизированную) систему;
 - 2.8. Ограничение числа параллельных сеансов доступа;
 - 2.9. Блокирование сеанса доступа пользователя при неактивности;
 - 2.10. Управление действиями пользователей до идентификации и аутентификации;
 - 2.11. Реализация защищенного удаленного доступа;
 - 2.12. Контроль доступа из внешних информационных (автоматизированных) систем.
3. Ограничение программной среды:
 - 3.1. Регламентация правил и процедур ограничения программной среды;

- 3.2. Управление запуском (обращениями) компонентов программного обеспечения;
- 3.3. Управление установкой (инсталляцией) компонентов программного обеспечения.
- 4. Защита машинных носителей информации:
 - 4.1. Регламентация правил и процедур защиты машинных носителей информации;
 - 4.2. Учет машинных носителей информации;
 - 4.3. Управление физическим доступом к машинным носителям информации;
 - 4.4. Контроль использования интерфейсов ввода (вывода) информации на съемные машинные носители информации;
 - 4.5. Контроль ввода (вывода) информации на съемные машинные носители информации;
 - 4.6. Контроль подключения съемных машинных носителей информации;
 - 4.7. Уничтожение (стирание) информации на машинных носителях информации.
- 5. Аудит безопасности:
 - 5.1. Регламентация правил и процедур аудита безопасности;
 - 5.2. Инвентаризация информационных ресурсов;
 - 5.3. Анализ уязвимостей и их устранение;
 - 5.4. Генерирование временных меток и/или синхронизация системного времени;
 - 5.5. Регистрация событий безопасности;
 - 5.6. Контроль и анализ сетевого трафика;
 - 5.7. Защита информации о событиях безопасности;
 - 5.8. Мониторинг безопасности;
 - 5.9. Реагирование на сбои при регистрации событий безопасности;

- 5.10. Анализ действий отдельных пользователей;
- 5.11. Проведение внутренних аудитов.
- 6. Антивирусная защита:
 - 6.1. Регламентация правил и процедур антивирусной защиты;
 - 6.2. Реализация антивирусной защиты;
 - 6.3. Антивирусная защита электронной почты и иных сервисов;
 - 6.4. Контроль использования архивных, исполняемых и зашифрованных файлов;
 - 6.5. Обновление базы данных признаков вредоносных компьютерных программ (вирусов);
 - 6.6. Использование средств антивирусной защиты различных производителей.
- 7. Предотвращение вторжений (компьютерных атак):
 - 7.1. Регламентация правил и процедур предотвращения вторжений (компьютерных атак);
 - 7.2. Обнаружение и предотвращение компьютерных атак;
 - 7.3. Обновление базы решающих правил.
- 8. Обеспечение целостности:
 - 8.1. Регламентация правил и процедур обеспечения целостности;
 - 8.2. Контроль целостности программного обеспечения;
 - 8.3. Ограничения по вводу информации в информационную (автоматизированную) систему;
 - 8.4. Контроль данных, вводимых в информационную (автоматизированную) систему;
 - 8.5. Контроль ошибочных действий пользователей по вводу и/или передаче информации и предупреждение пользователей об ошибочных действиях.
- 9. Обеспечение доступности:
 - 9.1. Регламентация правил и процедур обеспечения доступности;

- 9.2. Использование отказоустойчивых технических средств;
 - 9.3. Резервирование средств и систем;
 - 9.4. Контроль безотказного функционирования средств и систем;
 - 9.5. Резервное копирование информации;
 - 9.6. Обеспечение возможности восстановления информации;
 - 9.7. Обеспечение возможности восстановления программного обеспечения при нештатных ситуациях;
 - 9.8. Контроль предоставляемых вычислительных ресурсов и каналов связи.
10. Защита технических средств и систем:
- 10.1. Регламентация правил и процедур защиты технических средств и систем;
 - 10.2. Организация контролируемой зоны;
 - 10.3. Управление физическим доступом;
 - 10.4. Размещение устройств вывода (отображения) информации, исключающее ее несанкционированный просмотр;
 - 10.5. Защита от внешних воздействий.
11. Защита информационной (автоматизированной) системы и ее компонентов:
- 11.1. Регламентация правил и процедур защиты информационной (автоматизированной) системы и ее компонентов;
 - 11.2. Разделение функций по управлению (администрированию) информационной (автоматизированной) системой с иными функциями;
 - 11.3. Защита периметра информационной (автоматизированной) системы;
 - 11.4. Эшелонированная защита информационной (автоматизированной) системы;

- 11.5. Сегментирование информационной (автоматизированной) системы;
 - 11.6. Организация демилитаризованной зоны;
 - 11.7. Управление сетевыми потоками;
 - 11.8. Соккрытие архитектуры и конфигурации информационной (автоматизированной) системы;
 - 11.9. Защита неизменяемых данных;
 - 11.10. Защита от спама;
 - 11.11. Защита информации при ее передаче по каналам связи;
 - 11.12. Обеспечение доверенных канала, маршрута;
 - 11.13. Запрет несанкционированной удаленной активации периферийных устройств;
 - 11.14. Обеспечение подлинности сетевых соединений;
 - 11.15. Защита беспроводных соединений;
 - 11.16. Исключение доступа через общие ресурсы;
 - 11.17. Защита от угроз отказа в обслуживании (DOS, DDOS-атак);
 - 11.18. Управление сетевыми соединениями;
 - 11.19. Защита информации при использовании мобильных устройств;
 - 11.20. Управление перемещением виртуальных машин (контейнеров) и обрабатываемых на них данных.
12. Реагирование на компьютерные инциденты:
- 12.1. Регламентация правил и процедур реагирования на компьютерные инциденты;
 - 12.2. Выявление компьютерных инцидентов;
 - 12.3. Информирование о компьютерных инцидентах;
 - 12.4. Анализ компьютерных инцидентов;
 - 12.5. Устранение последствий компьютерных инцидентов;
 - 12.6. Принятие мер по предотвращению повторного возникновения компьютерных инцидентов;

- 12.7. Хранение и защита информации о компьютерных инцидентах.
- 13. Управление конфигурацией:
 - 13.1. Регламентация правил и процедур управления конфигурацией информационной (автоматизированной) системы;
 - 13.2. Управление изменениями;
 - 13.3. Установка (инсталляция) только разрешенного к использованию программного обеспечения.
- 14. Управление обновлениями программного обеспечения:
 - 14.1. Регламентация правил и процедур управления обновлениями программного обеспечения;
 - 14.2. Поиск, получение обновлений программного обеспечения от доверенного источника;
 - 14.3. Контроль целостности обновлений программного обеспечения;
 - 14.4. Тестирование обновлений программного обеспечения;
 - 14.5. Установка обновлений программного обеспечения.
- 15. Планирование мероприятий по обеспечению безопасности:
 - 15.1. Регламентация правил и процедур планирования мероприятий по обеспечению защиты информации;
 - 15.2. Разработка, утверждение и актуализация плана мероприятий по обеспечению защиты информации;
 - 15.3. Контроль выполнения мероприятий по обеспечению защиты информации.
- 16. Обеспечение действий в нештатных ситуациях:
 - 16.1. Регламентация правил и процедур обеспечения действий в нештатных ситуациях;
 - 16.2. Разработка плана действий в нештатных ситуациях;
 - 16.3. Обучение и отработка действий персонала в нештатных ситуациях;

- 16.4. Создание альтернативных мест хранения и обработки информации на случай возникновения нештатных ситуаций;
 - 16.5. Резервирование программного обеспечения, технических средств, каналов связи на случай возникновения нештатных ситуаций;
 - 16.6. Обеспечение возможности восстановления информационной (автоматизированной) системы в случае возникновения нештатных ситуаций;
 - 16.7. Анализ возникших нештатных ситуаций и принятие мер по недопущению их повторного возникновения.
17. Информирование и обучение персонала:
- 17.1. Регламентация правил и процедур информирования и обучения персонала;
 - 17.2. Информирование персонала об угрозах безопасности информации и о правилах безопасной работы;
 - 17.3. Обучение персонала правилам безопасной работы;
 - 17.4. Проведение практических занятий с персоналом по правилам безопасной работы;
 - 17.5. Контроль осведомленности персонала об угрозах безопасности информации и о правилах безопасной работы.

В представленном списке мер защиты информации представлены как технические решения, так и физические. В данной работе нас будут интересовать именно технические средства.

Также мы будем работать с ИСПДн, а защиту этой ИС регулируют следующие документы: **Федеральный закон “О персональных данных”** от 27.07.2006 № 152-ФЗ и **Приказ ФСТЭК России** от 18.02.2013 № 21 (ред. от 14.05.2020) “Об утверждении Состава и содержания организационных и технических мер по обеспечению безопасности

персональных данных при их обработке в информационных системах персональных данных”. Так как мы работаем с ГИС (Федеральный), у которого класс защищенности К1, а значит мы должны предъявить максимальные требования к безопасности ИСПДн, а это также УЗ1, только уже персональных данных. Меры защиты из приказа ФСТЭК России № 21:

1. Идентификация и аутентификация субъектов доступа и объектов доступа:
 - 1.1. Идентификация и аутентификация пользователей, являющихся работниками оператора;
 - 1.2. Идентификация и аутентификация устройств, в том числе стационарных, мобильных и портативных;
 - 1.3. Управление идентификаторами, в том числе создание, присвоение, уничтожение идентификаторов;
 - 1.4. Управление средствами аутентификации, в том числе хранение, выдача, инициализация, блокирование средств аутентификации и принятие мер в случае утраты и (или) компрометации средств аутентификации;
 - 1.5. Защита обратной связи при вводе аутентификационной информации;
 - 1.6. Идентификация и аутентификация пользователей, не являющихся работниками оператора (внешних пользователей).
2. Управление доступом субъектов доступа к объектам доступа:
 - 2.1. Управление (заведение, активация, блокирование и уничтожение)
 - 2.2. учетными записями пользователей, в том числе внешних пользователей;
 - 2.3. Реализация необходимых методов (дискреционный, мандатный, ролевой или иной метод), типов (чтение, запись, выполнение или иной тип) и правил разграничения доступа;
 - 2.4. Управление (фильтрация, маршрутизация, контроль соединений, однонаправленная передача и иные способы управления) информационными потоками между устройствами, сегментами информационной системы, а также между информационными системами;
 - 2.5. Разделение полномочий (ролей) пользователей,

- администраторов и лиц, обеспечивающих функционирование информационной системы;
- 2.6. Назначение минимально необходимых прав и привилегий пользователям, администраторам и лицам, обеспечивающим функционирование информационной системы;
 - 2.7. Ограничение неуспешных попыток входа в информационную систему (доступа к информационной системе);
 - 2.8. Блокирование сеанса доступа в информационную систему после установленного времени бездействия (неактивности) пользователя или по его запросу;
 - 2.9. Разрешение (запрет) действий пользователей, разрешенных до идентификации и аутентификации;
 - 2.10. Реализация защищенного удаленного доступа субъектов доступа к объектам доступа через внешние информационно-телекоммуникационные сети;
 - 2.11. Регламентация и контроль использования в информационной системе технологий беспроводного доступа;
 - 2.12. Регламентация и контроль использования в информационной системе мобильных технических средств;
 - 2.13. Управление взаимодействием с информационными системами сторонних организаций (внешние информационные системы);
 - 2.14. Обеспечение доверенной загрузки средств вычислительной техники.
3. Ограничение программной среды:
 - 3.1. Управление установкой (инсталляцией) компонентов программного обеспечения, в том числе определение компонентов, подлежащих установке, настройка параметров установки компонентов, контроль за установкой компонентов программного обеспечения;
 - 3.2. Установка (инсталляция) только разрешенного к использованию программного обеспечения и (или) его компонентов.
 4. Защита машинных носителей персональных данных:
 - 4.1. Учет машинных носителей персональных данных;
 - 4.2. Управление доступом к машинным носителям персональных данных;
 - 4.3. Уничтожение (стирание) или обезличивание персональных

данных на машинных носителях при их передаче между пользователями, в сторонние организации для ремонта или утилизации, а также контроль уничтожения (стирания) или обезличивания.

5. Регистрация событий безопасности:
 - 5.1. Определение событий безопасности, подлежащих регистрации, и сроков их хранения;
 - 5.2. Определение состава и содержания информации о событиях безопасности, подлежащих регистрации;
 - 5.3. Сбор, запись и хранение информации о событиях безопасности в течение установленного времени хранения;
 - 5.4. Мониторинг (просмотр, анализ) результатов регистрации событий безопасности и реагирование на них;
 - 5.5. Защита информации о событиях безопасности.
6. Антивирусная защита:
 - 6.1. Реализация антивирусной защиты;
 - 6.2. Обновление базы данных признаков вредоносных компьютерных программ (вирусов).
7. Обнаружение вторжений:
 - 7.1. Обнаружение вторжений;
 - 7.2. Обновление базы решающих правил.
8. Контроль (анализ) защищенности персональных данных:
 - 8.1. Выявление, анализ уязвимостей информационной системы и оперативное устранение вновь выявленных уязвимостей;
 - 8.2. Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации;
 - 8.3. Контроль работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации;
 - 8.4. Контроль состава технических средств, программного обеспечения и средств защиты информации;
 - 8.5. Контроль правил генерации и смены паролей пользователей, заведения и удаления учетных записей пользователей, реализации правил разграничения доступа, полномочий пользователей в информационной системе.
9. Обеспечение целостности информационной системы и

персональных данных:

- 9.1. Контроль целостности программного обеспечения, включая программное обеспечение средств защиты информации;
 - 9.2. Обнаружение и реагирование на поступление в информационную систему незапрашиваемых электронных сообщений (писем, документов) и иной информации, не относящихся к функционированию информационной системы (защита от спама).
10. Обеспечение доступности персональных данных:
- 10.1. Контроль безотказного функционирования технических средств, обнаружение и локализация отказов функционирования, принятие мер по восстановлению отказавших средств и их тестирование;
 - 10.2. Периодическое резервное копирование персональных данных на резервные машинные носители персональных данных;
 - 10.3. Обеспечение возможности восстановления персональных данных с резервных машинных носителей персональных данных (резервных копий) в течение установленного временного интервала.
11. Защита среды виртуализации:
- 11.1. Идентификация и аутентификация субъектов доступа и объектов доступа в виртуальной инфраструктуре, в том числе администраторов управления средствами виртуализации;
 - 11.2. Управление доступом субъектов доступа к объектам доступа в виртуальной инфраструктуре, в том числе внутри виртуальных машин;
 - 11.3. Регистрация событий безопасности в виртуальной инфраструктуре;
 - 11.4. Управление перемещением виртуальных машин (контейнеров) и обрабатываемых на них данных;
 - 11.5. Контроль целостности виртуальной инфраструктуры и ее конфигураций;
 - 11.6. Резервное копирование данных, резервирование технических средств, программного обеспечения виртуальной инфраструктуры, а также каналов связи внутри виртуальной инфраструктуры;
 - 11.7. Реализация и управление антивирусной защитой в

- виртуальной инфраструктуре;
- 11.8. Разбиение виртуальной инфраструктуры на сегменты (сегментирование виртуальной инфраструктуры) для обработки персональных данных отдельным пользователем и (или) группой пользователей.
12. Защита технических средств:
 - 12.1. Контроль и управление физическим доступом к техническим средствам, средствам защиты информации, средствам обеспечения функционирования, а также в помещения и сооружения, в которых они установлены, исключающие несанкционированный физический доступ к средствам обработки информации, средствам защиты информации и средствам обеспечения функционирования информационной системы, в помещения и сооружения, в которых они установлены;
 - 12.2. Размещение устройств вывода (отображения) информации, исключающее ее несанкционированный просмотр.
 13. Защита информационной системы, ее средств, систем связи и передачи данных:
 - 13.1. Разделение в информационной системе функций по управлению (администрированию) информационной системой, управлению (администрированию) системой защиты персональных данных, функций по обработке персональных данных и иных функций информационной системы;
 - 13.2. Обеспечение защиты персональных данных от раскрытия, модификации и навязывания (ввода ложной информации) при ее передаче (подготовке к передаче) по каналам связи, имеющим выход за пределы контролируемой зоны, в том числе беспроводным каналам связи;
 - 13.3. Обеспечение подлинности сетевых соединений (сеансов взаимодействия), в том числе для защиты от подмены сетевых устройств и сервисов;
 - 13.4. Защита архивных файлов, параметров настройки средств защиты информации и программного обеспечения и иных данных, не подлежащих изменению в процессе обработки персональных данных;

- 13.5. Разбиение информационной системы на сегменты (сегментирование информационной системы) и обеспечение защиты периметров сегментов информационной системы;
 - 13.6. Защита беспроводных соединений, применяемых в информационной системе.
14. Выявление инцидентов и реагирование на них:
- 14.1. Определение лиц, ответственных за выявление инцидентов и реагирование на них;
 - 14.2. Обнаружение, идентификация и регистрация инцидентов;
 - 14.3. Своевременное информирование лиц, ответственных за выявление инцидентов и реагирование на них, о возникновении инцидентов в информационной системе пользователями и администраторами;
 - 14.4. Анализ инцидентов, в том числе определение источников и причин возникновения инцидентов, а также оценка их последствий;
 - 14.5. Принятие мер по устранению последствий инцидентов;
 - 14.6. Планирование и принятие мер по предотвращению повторного возникновения инцидентов.
15. Управление конфигурацией информационной системы и системы защиты персональных данных:
- 15.1. Определение лиц, которым разрешены действия по внесению изменений в конфигурацию информационной системы и системы защиты персональных данных;
 - 15.2. Управление изменениями конфигурации информационной системы и системы защиты персональных данных;
 - 15.3. Анализ потенциального воздействия планируемых изменений в конфигурации информационной системы и системы защиты персональных данных на обеспечение защиты персональных данных и согласование изменений в конфигурации информационной системы с должностным лицом (работником), ответственным за обеспечение безопасности персональных данных;
 - 15.4. Документирование информации (данных) об изменениях в конфигурации информационной системы и системы защиты персональных данных.

Приведем полный список мер по обеспечению безопасности

персональных данных, но в нашей работе нас интересуют именно технические (компьютерные) средства защиты.

Настройка Unix системы

В связи с отсутствием Qubes OS в реестре сертифицированных операционных систем Linux, за основу настройки был принят методический документ ФСТЭК России «Рекомендации по безопасной настройке операционных систем Linux». Как следует из п. 1.3 данного документа, данные рекомендации следует использовать в случае временного использования ОС Linux, не являющегося сертифицированной отечественной операционной системой.

“Пункт 1.3. Настоящие Рекомендации подлежат реализации **в государственных информационных системах и на объектах критической информационной инфраструктуры** Российской Федерации, построенных с использованием операционных систем Linux, несертифицированных по требованиям безопасности информации, до их замены на сертифицированные отечественные операционные системы.”

Настройки безопасности

Настройка авторизации в операционных системах Linux

При настройке авторизации в операционной системе Linux необходимо:

Рекомендация:

2.1.1. Не допускать использование учетных записей пользователей с пустыми паролями. Настроить учетные записи таким образом, чтобы каждый пользователь системы либо имел пароль, либо был заблокирован по паролю. В системах Linux данную возможность обеспечивает файл `/etc/shadow`.

Выполнение:

По умолчанию в Parrot OS создается 1 пользовательская УЗ с доступом в группу *sudoers*. Ей был присвоен сложный пароль.

Рекомендация:

2.1.2. Обеспечить отключение входа суперпользователя в систему по протоколу SSH путем установки для параметра `PermitRootLogin` значения `no` в файле `/etc/ssh/sshd_config`.

Выполнение:

Рекомендация была выполнена путем модификации конфигурационного файла `/etc/ssh/sshd_config`. На Рисунке НОМЕР показано корректное значение параметра `PermitRootLogin`.


```

[every@parrot]~$ cat /etc/ssh/sshd_config | grep PermitRootLogin
PermitRootLogin no
# the setting of "PermitRootLogin prohibit-password".
[every@parrot]~$

```

Рисунок 1 – Фрагмент конфигурационного файла /etc/ssh/sshd_config с установленным параметром PermitRootLogin no, запрещающим вход суперпользователя по протоколу SSH

Ограничение механизмов получения привилегий

При ограничении механизмов получения привилегий необходимо:

Рекомендация:

2.2.1. Обеспечить ограничение доступа к команде su путем добавления в файл /etc/pam.d/su следующей строки: auth required pam_wheel.so use_uid. Задать список пользователей в записи для группы wheel в файле /etc/group:

wheel:x:10:root,<user list>.

Выполнение:

Так как Parrot OS является форком Debian OS, там исторически не используется группа wheel. Однако, чтобы выполнить рекомендации ФСТЭК, была создана группа wheel и настроен PAM таким образом, чтобы только пользователи - члены wheel могли использовать команду su.

```

[every@parrot]~$ cat /etc/pam.d/su | grep 'pam_wheel.so use_uid'
auth      required    pam_wheel.so use_uid
[every@parrot]~$

```

Рисунок 2 – Содержимое файла /etc/pam.d/su с добавленной строкой auth required pam_wheel.so use_uid, ограничивающей использование команды su

```
[X]-[every@parrot]-[~]
$ getent group wheel
wheel:x:1001:every,root
[every@parrot]-[~]
$
```

Рисунок 3 – Запись группы wheel в файле /etc/group, содержащая список разрешенных пользователей (включая root и администратора)

Рекомендация:

2.2.2. Ограничить список пользователей, которым разрешено использовать команду sudo и разрешенных к выполнению через sudo команд путем пересмотра файла /etc/sudoers.

Выполнение:

Файл /etc/sudoers был пересмотрен. Согласно нему, доступ к команде sudo имеет привилегированный пользователь root, а также все члены группы sudo.

```
[every@parrot]-[~]
$ sudo cat /etc/sudoers | tail

# User privilege specification
root    ALL=(ALL:ALL) ALL

# Allow members of group sudo to execute any command
%sudo   ALL=(ALL:ALL) ALL

# See sudoers(5) for more information on "@include" directives:

@includedir /etc/sudoers.d
[every@parrot]-[~]
$
```

Рисунок 4 – Фрагмент файла /etc/sudoers, демонстрирующий настройки доступа к команде sudo для пользователя root и членов группы sudo

В группе sudo состоит один пользователь - every. Every - это УЗ администратора системы. Данные настройки безопасны, посторонние УЗ не имеют доступа к команде sudo.

```
[every@parrot]~$  
$getent group sudo  
sudo:x:27:every  
[every@parrot]~$
```

Рисунок 5 – Состав группы sudo, включающий единственного пользователя every – учетную запись администратора системы

Настройка прав доступа к объектам файловой системы

При настройке прав доступа к объектам файловой системы необходимо:

Рекомендация:

2.3.1. Установить корректные права доступа к файлам настройки пользователей, а именно к файлам с перечнями пользовательских идентификаторов (/etc/passwd) и групп (/etc/group), либо хранилищам хешей паролей

(в операционных системах GNU/Linux, Solaris, HP-UX: /etc/shadow, AIX: /etc/security/passwd), с помощью команд:

```
chmod 644 /etc/passwd;  
chmod 644 /etc/group;  
chmod go-rwx /etc/shadow.
```

Выполнение:

Были установлены корректные права доступа к файлам настройки пользователей /etc/passwd, /etc/group, /etc/shadow. На Рисунке показано состояние прав данных файлов после конфигурации.

```

[every@parrot]~$ ls -l /etc/passwd /etc/group /etc/shadow
-rw-r--r-- 1 root root 671 Oct 22 02:26 /etc/group
-rw-r--r-- 1 root root 1111 Oct 22 02:06 /etc/passwd
-rw----- 1 root shadow 671 Oct 22 02:06 /etc/shadow
[every@parrot]~$

```

Рисунок 6 – Права доступа к файлам /etc/passwd, /etc/group и /etc/shadow после применения рекомендованных настроек (644, 644, 000 соответственно)

Рекомендация:

2.3.2. Установить корректные права доступа к файлам запущенных процессов путем выполнения команды вида: `chmod go-w /путь/к/файлу` для всех исполняемых файлов, запущенных в настоящий момент, и соответствующих библиотек. После этого необходимо осуществить проверку, что директория, содержащая данный файл, а также все родительские директории недоступны для записи непривилегированным пользователям.

Выполнение:

Рассмотрим все запущенные процессы.

```

[every@parrot]~$ ps -aux
USER      PID  %CPU %MEM    VSZ   RSS TTY      STAT START   TIME COMMAND
root         1   0.0  0.0   3072   2176 ?        SL    01:43   0:00 /init
root         5   0.0  0.0   3072   1792 ?        SL    01:43   0:00 plan9 --control-socket 6
root       140   0.0  0.0   3080   1024 ?        Ss    01:54   0:00 /init
root       141   0.0  0.0   3096   1028 ?        S     01:54   0:00 /init
every      142   0.0  0.0   8400   4864 pts/0    Ss    01:54   0:00 -bash
every     3131   0.0  0.0  11048   4608 pts/0    R+    03:14   0:00 ps -aux
[every@parrot]~$

```

Рисунок 7 – Список запущенных процессов, полученный с помощью команды `ps aux`, используемый для анализа исполняемых файлов /init и plan9 - это часть слоя совместимости WSL2, и эти процессы недоступны для изменения из гостевой операционной системы даже с правами привилегированного пользователя.

ps -aux - это процесс, который позволил вывести на экран таблицу запущенных процессов. На самом деле он не запущен в системе на постоянной основе.

Рассмотрим процесс 142, *-bash*. Как показано на Рисунке, его исполняемый файл находится по пути /usr/bin/bash, а исполняемый файл /usr/bin/bash имеет корректные права доступа (write исключен для всех кроме владельца файла)

```
[every@parrot]~  
$readlink /proc/142/exe  
/usr/bin/bash (deleted)  
[every@parrot]~  
$ls -l /usr/bin/bash  
-rwxr-xr-x 1 root root 1265648 Sep  7 01:07 /usr/bin/bash  
[every@parrot]~  
$
```

Рисунок 8 – Права доступа к исполняемому файлу /usr/bin/bash, подтверждающие отсутствие прав на запись для группы и остальных пользователей

Далее, как мы видим на Рисунке, все родительские директории также имеют корректные права.

```
[every@parrot]~  
$ls -ld /usr/bin  
drwxr-xr-x 2 root root 20480 Oct 22 02:48 /usr/bin  
[every@parrot]~  
$ls -ld /usr  
drwxr-xr-x 12 root root 4096 Jul  8 03:07 /usr  
[every@parrot]~  
$
```

Рисунок 9 – Права доступа к родительским директориям исполняемого файла /usr/bin/bash, исключающие запись для непривилегированных пользователей

Рекомендация:

2.3.3. Установить корректные права доступа к файлам, выполняющимся с помощью планировщика задач cron неавторизованными

пользователями путем выполнения команды `chmod go-w путь_к_файлу` для каждого файла (либо команды), который вызывается из заданий `cron`. В противном случае это может привести к выполнению произвольного кода от имени владельца задания `cron` (в том числе `root`, что приведет к полной компрометации операционной системы).

Выполнение:

Как показано на Рисунке, в нашей системе нет пользовательских `cron` задач. Таким образом, эта рекомендация выполнена.

```
[every@parrot]~$ sudo bash list_all_crontabs.sh
== System crontabs ==
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6 * * 7 root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6 1 * * root test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r

== User crontabs ==
[every@parrot]~$
```

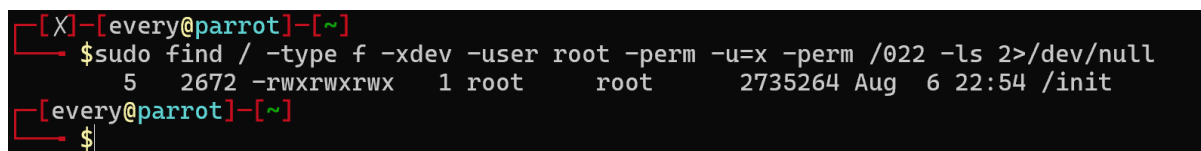
Рисунок 10 – Отсутствие пользовательских заданий в планировщике `cron` (проверка через `crontab -l` для всех пользователей)

Рекомендация:

2.3.4. Установить корректные права доступа к файлам, выполняемым с помощью `sudo` путем изменения владельца командой `chown root путь_к_файлу` для каждого исполняемого файла, который можно запускать с привилегиями суперпользователя `root`, но владельцем которого является обычный пользователь и выполнения команды `chmod go-w путь_к_файлу` для каждого исполняемого файла, который можно запускать с привилегиями суперпользователя `root` и к которому имеют доступ на запись все пользователи.

Выполнение:

Был проведен анализ файла /etc/sudoers и дополнительных файлов конфигурации /etc/sudoers.d/*, так как система установлена “чисто”, в этих файлах нет выделенных разрешений на выполнение конкретных файлов с помощью sudo. Также по всей файловой системе (за исключением иных ФС) был проведен поиск файлов, которыми владеет root, но которые разрешают операции записи для пользователей типа “группа” или “иные”. Был найден 1 такой файл, /init. /init это служебный read-only файл гипервизора, его невозможно редактировать из WSL, он не представляет угрозы.



```
[X]-[every@parrot]-[~]  
$ sudo find / -type f -xdev -user root -perm -u=x -perm /022 -ls 2>/dev/null  
5 2672 -rwxrwxrwx 1 root root 2735264 Aug 6 22:54 /init  
[every@parrot]-[~]  
$
```

Рисунок 11 – Результат поиска файлов с небезопасными правами доступа, принадлежащих пользователю root, но доступных на запись другим
(обнаружен только системный файл /init)

Рекомендация:

2.3.5. Установить корректные права доступа к стартовым скриптам системы путем выполнения команды `chmod o-w <filename>` к каждому файлу в директориях /etc/rc#.d, а также к файлам .service, присутствующим в системе.

Выполнение:

Были установлены корректные права доступа к стартовым скриптам системы, расположенным в директориях /etc/rc#.d, а также к файлам сервисов .service. Права записи для остальных пользователей были сняты. На Рисунке показано состояние прав данных файлов после конфигурации.

```

[X]~[every@parrot]~[~]
$find /etc/rc*.d -type f -perm /002 -ls 2>/dev/null
[every@parrot]~[~]
$find / -type f -xdev -name "*.service" -perm /002 -ls 2>/dev/null
[X]~[every@parrot]~[~]
$

```

Рисунок 12 – Права доступа к стартовым скриптам системы в каталогах /etc/rc*.d и файлам .service, с отключенной записью для остальных пользователей

Рекомендация:

2.3.6. Установить корректные права доступа к системным файлам заданий (конфигурационным файлам) cron при помощи команды `chmod go-wx путь_к_файлу_или_директории`.

К системным файлам-описаниям очередей cron относятся следующие файлы (могут присутствовать не всегда, в зависимости от операционной системы и ее настроек):

- /etc/crontab;
- /etc/cron.d (директория и файлы внутри нее);
- /etc/cron.hourly (директория и файлы внутри нее);
- /etc/cron.daily (директория и файлы внутри нее);
- /etc/cron.weekly (директория и файлы внутри нее);
- /etc/cron.monthly (директория и файлы внутри нее).

Выполнение:

Были установлены корректные права доступа к системным файлам конфигурации планировщика cron, а также к директориям и файлам в каталогах /etc/cron.d, /etc/cron.hourly, /etc/cron.daily, /etc/cron.weekly и /etc/cron.monthly. Для данных объектов были удалены права записи и выполнения для группы и остальных пользователей. На Рисунке показано состояние прав данных файлов после конфигурации.


```
[X]~[every@parrot]~[~]
$ls -ld /etc/crontab /etc/cron.d /etc/cron.hourly /etc/cron.daily /etc/cron.weekly /etc/cron.monthly 2>/dev/null
drwxr-xr-x 2 root root 4096 Jul  8 03:08 /etc/cron.d
drwxr-xr-x 2 root root 4096 Jul  8 03:09 /etc/cron.daily
drwxr-xr-x 2 root root 4096 Jul  8 03:08 /etc/cron.hourly
drwxr-xr-x 2 root root 4096 Jul  8 03:08 /etc/cron.monthly
-rw-r--r-- 1 root root 1042 Mar  2 2023 /etc/crontab
drwxr-xr-x 2 root root 4096 Jul  8 03:09 /etc/cron.weekly
[every@parrot]~[~]
$find /etc/cron.d /etc/cron.hourly /etc/cron.daily /etc/cron.weekly /etc/cron.monthly \
-maxdepth 1 -type f -ls 2>/dev/null
393      4 -rw-r--r--  1 root    root          201 Jun  6 20:12 /etc/cron.d/e2scrub_all
392      4 -rw-r--r--  1 root    root          102 Mar  2 2023 /etc/cron.d/.placeholder
1124     4 -rw-r--r--  1 root    root          102 Mar  2 2023 /etc/cron.hourly/.placeholder
1291     4 -rwxr-xr-x  1 root    root          123 Sep  1 2023 /etc/cron.daily/dpkg
1288     4 -rwxr-xr-x  1 root    root         1395 Mar 13 2023 /etc/cron.daily/man-db
1290     4 -rw-r--r--  1 root    root          102 Mar  2 2023 /etc/cron.daily/.placeholder
1292     4 -rwxr-xr-x  1 root    root          377 Dec 14 2022 /etc/cron.daily/logrotate
1287     4 -rwxr-xr-x  1 root    root          2211 Feb 10 2018 /etc/cron.daily/locate
1289     4 -rwxr-xr-x  1 root    root          1478 May 25 2023 /etc/cron.daily/apt-compat
765      4 -rwxr-xr-x  1 root    root         1055 Mar 13 2023 /etc/cron.weekly/man-db
766      4 -rw-r--r--  1 root    root          102 Mar  2 2023 /etc/cron.weekly/.placeholder
1218     4 -rw-r--r--  1 root    root          102 Mar  2 2023 /etc/cron.monthly/.placeholder
[every@parrot]~[~]
$
```

Рисунок 13 – Права доступа к системным файлам и каталогам планировщика cron (/etc/crontab, /etc/cron.d/ и др.), защищенные от записи и выполнения для группы и остальных

Рекомендация:

2.3.7. Установить корректные права доступа к пользовательским файлам заданий cron при помощи команды вида: `chmod go-w путь_к_файлу_заданий`.

Выполнение:

С помощью команды `find` были проанализированы права доступа к пользовательским файлам конфигурации заданий cron. Некорректных прав доступа не выявлено, внесение изменений не потребовалось.

```
[every@parrot]~[~]
$sudo find /var/spool/cron /var/spool/cron/crontabs -type f -perm /022 -ls 2>/dev/null
[every@parrot]~[~]
$
```

Рисунок 14 – Проверка прав доступа к пользовательским cron-файлам с помощью команды `find`; нарушений не выявлено

Рекомендация:

2.3.8. Установить корректные права доступа к исполняемым файлам и библиотекам операционной системы путем анализа корректности прав доступа к утилитам и системным библиотекам, расположенным по стандартным путям (/bin, /usr/bin, /lib, /lib64 и другим путям), а также к модулям ядра (для Linux: /lib/modules/версия-текущего-ядра).

Местоположение большинства стандартных исполняемых файлов указано в переменной \$PATH пользователя root.

Выполнение:

Были проанализированы права доступа к системным исполняемым файлам, библиотекам и модулям ядра, расположенным в стандартных каталогах `/bin`, `/usr/bin`, `/lib`, `/lib64` и `/lib/modules/6.6.87.2-microsoft-standard-WSL2`. Некорректных прав доступа не выявлено, внесение изменений не потребовалось.

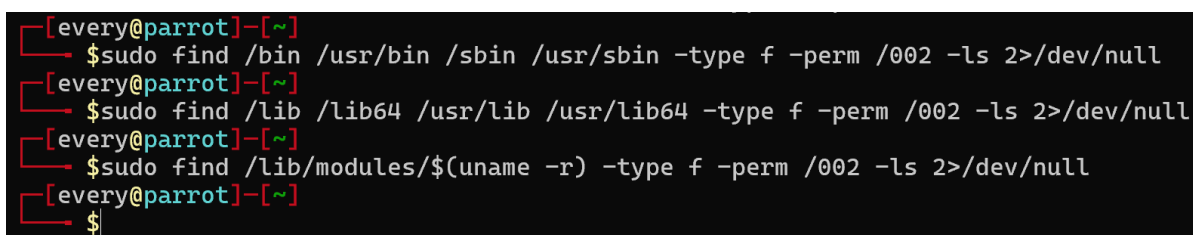
A screenshot of a terminal window with a dark background. It shows four lines of commands being executed by a user named 'every' on a system named 'parrot'. The commands use 'sudo find' to check permissions on various system directories. The first command checks /bin, /usr/bin, and /sbin. The second checks /lib and /lib64. The third checks /lib/modules for the current kernel version. The fourth command is partially visible. The prompt is '[every@parrot]~' and the shell is '\$'.

Рисунок 15 – Анализ прав доступа к системным исполняемым файлам, библиотекам и модулям ядра в стандартных каталогах (`/bin`, `/lib`, `/usr/bin` и др.); права соответствуют требованиям безопасности

Рекомендация:

2.3.9. Установить корректные права доступа к SUID/SGID-приложениям путем проведения аудита системы на предмет поиска всех SUID/SGID-приложений – права доступа к каждому из них не должны позволять остальным пользователям изменять его содержимое (в особенности если это SUID-приложение и его владелец root). В противном случае следует выполнить команду вида: `chmod go-w /путь/к/приложению`. Проверить, что среди выявленных SUID/SGID-приложений не присутствуют лишние (например, если определен «белый» список таких приложений), в противном случае следует снять с таких приложений SUID/SGID-биты.

Выполнение:

Был проведен аудит SUID/SGID-приложений в системе. Некорректных прав доступа, позволяющих изменение содержимого

файлов остальным пользователям, не выявлено. Лишние SUID/SGID-приложения отсутствуют. Внесение изменений не потребовалось.

```
[every@parrot]~  
$ sudo find / -xdev -type f \( -perm -4000 -o -perm -2000 \) -perm /022 -ls  
[every@parrot]~  
$
```

Рисунок 16 – Список SUID/SGID-файлов в системе, полученный с помощью команды `find / -type f \( -perm -4000 -o -perm -2000 \) 2>/dev/null;` все файлы имеют корректные права

Рекомендация:

2.3.10. Установить корректные права доступа к содержимому домашних директорий пользователей (.bash_history, .history, .sh_history и т. п. - файлы истории команд оболочек, .bash_profile, .bashrc, .profile, .bash_logout и т. п. - файлы настройки оболочки, .rhosts - настройки R-подсистем) путем установки на каждый из указанных файлов корректных прав доступа с помощью команды вида: `chmod go-rwx путь_к_файлу`.

Выполнение:

```

[every@parrot]~$ cat check_history_files.sh
targets='
.bash_history
.history
.sh_history
.bash_profile
.bashrc
.profile
.bash_logout
.rhosts
.zsh_history
.zprofile
.zshrc
.kshrc
'

for t in $targets; do
    find . -xdev -type f -name "$t" -perm /077 -ls
done
[every@parrot]~$ ./check_history_files.sh
[every@parrot]~$

```

Рисунок 17 – Проверка конфиденциальных файлов в домашней директории пользователя (.bash_history, .bashrc и др.) на отсутствие доступа для группы и остальных пользователей

Файлы домашней директории, способные содержать чувствительные данные, были проверены командой `find` на наличие прав для группы или иных пользователей. Таких файлов обнаружено не было.

Рекомендация:

2.3.11. Установить корректные права доступа к домашним директориям пользователей с помощью команды `chmod 700 домашняя_директория`.

Выполнение:

Все домашние директории (директории в `/home`) соответствуют правам 700.

```

[every@parrot]~[/home]
$ ls -la
total 12
drwxr-xr-x  3 root  root  4096 Oct 22 01:43 .
drwxr-xr-x 18 root  root  4096 Oct 25 03:42 ..
drwx----- 12 every every 4096 Oct 25 06:05 every

```

Рисунок 18 – Права доступа к домашним каталогам пользователей в /home, установленные в 700 (доступ только владельцу)

Настройка механизмов защиты ядра Linux

При настройке механизмов защиты ядра Linux необходимо:

Рекомендация:

2.4.1. Ограничить доступ к журналу ядра путем установки значения sysctl-опции `kernel.dmesg_restrict=1`. Журнал ядра должен быть доступен только пользователям, которые обладают разрешением `CAP_SYSLOG` (администраторы системы).

Выполнение:

Доступ к журналу ядра был ограничен

```

[every@parrot]~[/home]
$ sysctl kernel.dmesg_restrict
kernel.dmesg_restrict = 1
[every@parrot]~[/home]
$ sudo -u nobody dmesg | head
dmesg: read kernel buffer failed: Operation not permitted
[every@parrot]~[/home]
$

```

Рисунок 19 – Установка значения `kernel.dmesg_restrict=1` через sysctl, ограничивающая доступ к журналу ядра только привилегированным пользователям

Рекомендация:

2.4.2. Заменить ядерные адреса в /proc и других интерфейсах на 0 путем установки значения sysctl-опции `kernel.kptr_restrict=2`.

Выполнение:

Sysctl-опция `kernel.kptr_restrict` была установлена в значение 2.

```
[every@parrot]~[/home]
$ sysctl kernel.kptr_restrict
kernel.kptr_restrict = 2
[every@parrot]~[/home]
$
```

Рисунок 20 – Установка значения `kernel.kptr_restrict=2` через `sysctl`, скрывающая ядерные адреса в `/proc` и других интерфейсах

ВЫВОД

В рамках выполнения лабораторной работы, была проведена настройка Parrot OS в соответствии с рекомендациями ФСТЭК.

СПИСОК ИСПОЛЬЗУЕМЫХ ИСТОЧНИКОВ

1. ГОСТ Р 56938-2016. Защита информации. Защита информации при использовании технологий виртуализации. – Введ. 2017-06-01. – М.: Стандартинформ, 2016. – VI, 30 с.
2. О безопасности критической информационной инфраструктуры Российской Федерации [Текст] : федер. закон от 26.07.2017 № 187-ФЗ : принят Гос. Думой 21.07.2017 : одобр. Советом Федерации 25.07.2017 : [ред. от 04.02.2024]. – Москва, 2017. – Текст : электронный // КонсультантПлюс : [сайт]. – URL: https://www.consultant.ru/document/cons_doc_LAW_220885/ (дата обращения: 27.12.2025).
3. Об информации, информационных технологиях и о защите информации [Текст] : федер. закон от 27.07.2006 № 149-ФЗ : принят Гос. Думой 21.07.2006 : одобр. Советом Федерации 26.07.2006 : [ред. от 24.02.2024]. – Москва, 2006. – Текст : электронный // КонсультантПлюс : [сайт]. – URL: https://www.consultant.ru/document/cons_doc_LAW_61798/ (дата обращения: 27.12.2025).
4. Об утверждении Требований о защите информации, не составляющей государственную тайну, содержащейся в государственных информационных системах [Текст] : приказ ФСТЭК России от 11.02.2013 № 17 : зарег. в Минюсте России 20.03.2013 № 27840 : [ред. от 28.08.2024]. – Москва, 2013. – Текст : электронный // КонтурНорматив : [сайт]. – URL: <https://normativ.kontur.ru/document?moduleId=1&documentId=481221> (дата обращения: 27.12.2025).
5. Об утверждении Требований по обеспечению безопасности значимых объектов критической информационной инфраструктуры Российской Федерации [Текст] : приказ ФСТЭК России от 25.12.2017

№ 239 : зарег. в Минюсте России 08.02.2018 № 49918 : [ред. от 28.08.2024]. – Москва, 2017. – Текст : электронный // КонтурНорматив : [сайт]. – URL: <https://normativ.kontur.ru/document?moduleId=1&documentId=481283> (дата обращения: 27.12.2025).

6. Рекомендации по безопасной настройке операционных систем Linux [Текст] : метод. документ : утв. ФСТЭК России 18.10.2023. – Рег. № 75491 в Минюсте России 13.11.2023. – М.: ФСТЭК России, 2023. – 236 с.